PsExec Hunt Lab

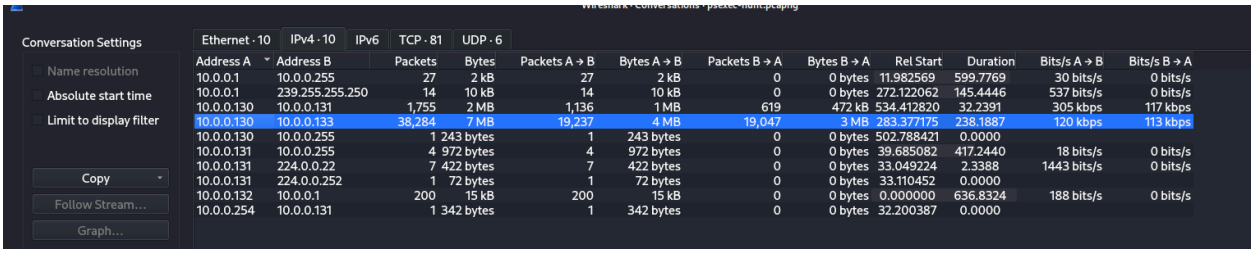
1. Kịch bản

- IDS cảnh báo hoạt động lateral movement đáng ngờ liên quan PsExec. Cho thấy khả năng truy cập và di chuyển trái phép trên network. Điều tra file pcap để xác định: điểm xâm nhập, machine mục tiêu, phạm vi xâm phạm, IOC tiết lộ tactic và mục tiêu của attacker

2. Write up

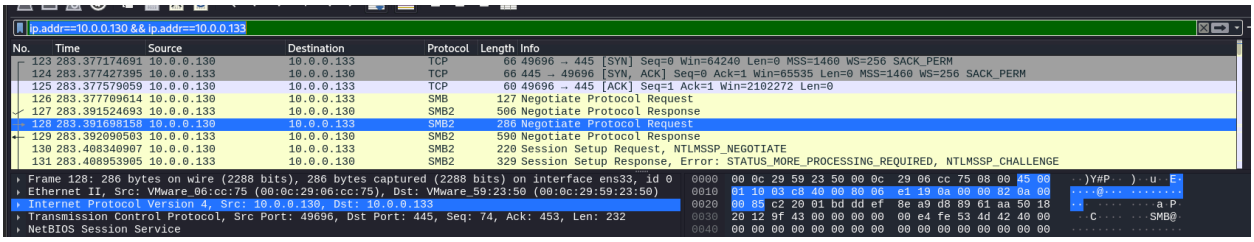
1. To effectively trace the attacker's activities within our network, can you identify the IP address of the machine from which the attacker initially gained access?

- Yêu cầu: tìm IP máy mà attacker dùng để truy cập ban đầu
- As: 10.0.0.130
- Xem thông tin thống kê về conversations phát hiện 2 IP 10.0.0.130 ↔ 10.0.0.133 trao đổi với lượng dữ liệu lớn hơn nhiều so với các conversation khác



Address A	Address B	Packets	Bytes	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
10.0.0.1	10.0.0.255	27	2 kB	27	2 kB	0	0 bytes	11.982569	599.7769	30 bits/s	0 bits/s
10.0.0.1	239.255.255.250	14	10 kB	14	10 kB	0	0 bytes	272.122062	145.4446	537 bits/s	0 bits/s
10.0.0.130	10.0.0.131	1,755	2 MB	1,136	1 MB	619	472 kB	534.412820	32.2391	305 kbps	117 kbps
10.0.0.130	10.0.0.133	38,284	7 MB	19,237	4 MB	19,047	3 MB	283.377175	238.1887	120 kbps	113 kbps
10.0.0.130	10.0.0.255	1	243 bytes	1	243 bytes	0	0 bytes	502.788421	0.0000		
10.0.0.131	10.0.0.255	4	972 bytes	4	972 bytes	0	0 bytes	39.685082	417.2440	18 bits/s	0 bits/s
10.0.0.131	224.0.0.22	7	422 bytes	7	422 bytes	0	0 bytes	33.049224	2.3388	1443 bits/s	0 bits/s
10.0.0.131	224.0.0.252	1	72 bytes	1	72 bytes	0	0 bytes	33.110452	0.0000		
10.0.0.132	10.0.0.1	200	15 kB	200	15 kB	0	0 bytes	0.000000	636.8324	188 bits/s	0 bits/s
10.0.0.254	10.0.0.131	1	342 bytes	1	342 bytes	0	0 bytes	32.200387	0.0000		

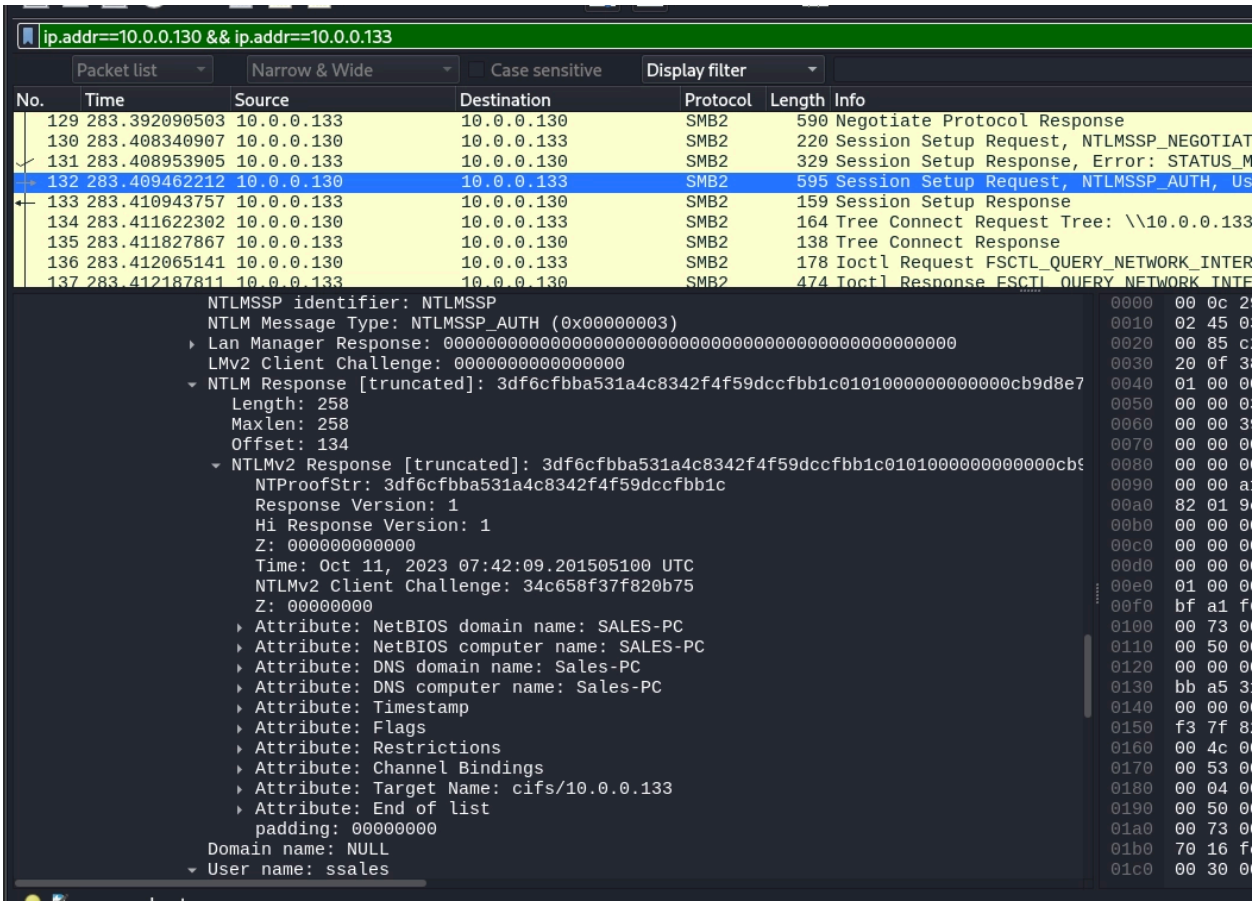
- Sử dụng bộ lọc ip.addr==10.0.0.130 && ip.addr==10.0.0.133 để xem 2 máy này trao đổi gì với nhau
- Phát hiện máy 10.0.0.130 gửi yêu cầu kết nối TCP đến máy 10.0.0.133 → đây có thể là máy mà attacker dùng để truy cập ban đầu cho attack



2. To fully understand the extent of the breach, can you determine the machine's hostname to which the attacker first pivoted?

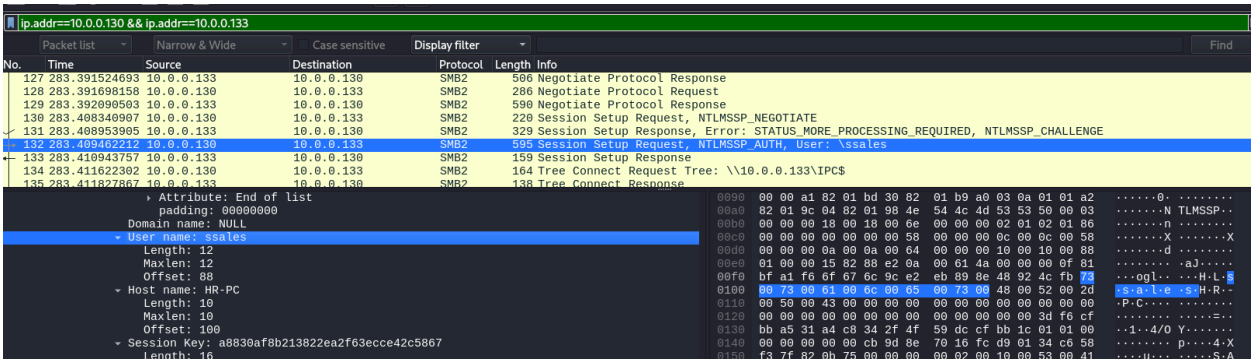
- Yêu cầu: xác định các hostname bị attacker nhắm đến → phạm vi xâm phạm
- As: SALES-PC
- Quy trình kết nối SMB
  - Thiết lập kết nối TCP
  - Thương lượng giao thức (Protocol Negotiation)
    - Client: Negotiate Protocol Request → list phiên bản SMB nó hiểu
    - Server: Negotiate Protocol Response → sererver chọn phiên bản và gửi thông số kỹ thuật
  - Thiết lập phiên làm việc (Session Setup - Authentication)
    - Client: Session Setup Request → gửi in4 xác thực (username, domain, hash,..)
    - Server: Session Setup Response → check in4 đúng thì trả Session ID duy trì phiên
  - Kết nối thực thể (Tree Connect)
    - Client: Tree Connect Request → gửi path tài nguyên
    - Server: Tree Connect Response → trả Tree ID đại diện kết nối đến thư mục đó
  - Ngắt kết nối (Tree Disconnect & Logoff)
    - Tree Disconnect: Client ngắt kết nối với thư mục
    - Logoff: Client kết thúc SMB
    - TCP Teardown: giải phóng kết nối mạng

- Dựa theo quy trình kết nối chọn gói tin với Session Setup Request → gói tin này chứa thông tin định danh thiết bị yêu cầu kết nối
    - Attacker dùng xác thực NTLM
        - Dùng kỹ thuật Pass-The-Hash xác thực bằng NTLM hash lấy từ file SAM hoặc bộ nhớ LSASS của máy nạn nhân



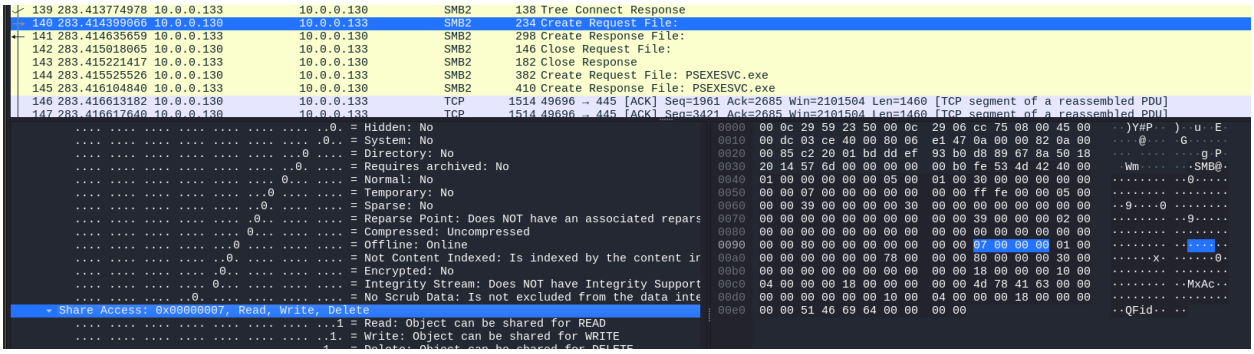
3. Knowing the username of the account the attacker used for authentication will give us insights into the extent of the breach. What is the username utilized by the attacker for authentication?

- Yêu cầu: tìm username dùng để xác thực → mức độ xâm phạm
- As: ssales
- Dựa vào cùng gói tin với câu 2, tìm trường username và lấy thông tin

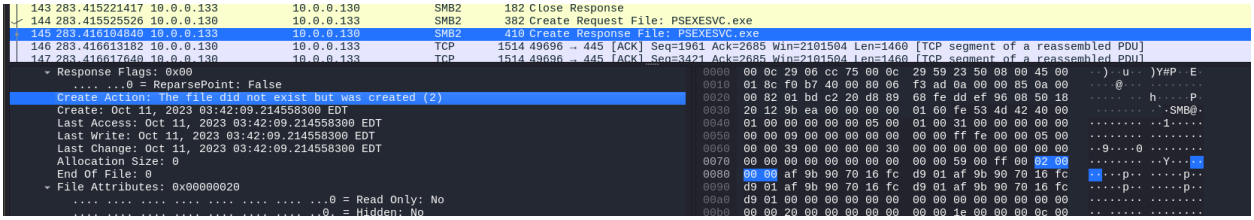


4. After figuring out how the attacker moved within our network, we need to know what they did on the target machine. What's the name of the service executable the attacker set up on the target?

- Yêu cầu: tìm ra attacker đã làm gì trên máy mục tiêu
- As: PSEXESVC.exe
- Đầu tiên attacker gửi Tree Connect Request tới \\10.0.0.133\IPC$, attacker xem được
  - Lấy thông tin full user và group qua \pipe\samr
  - List thư mục chia sẻ công khai qua \pipe\srvsvc
  - Một số thông tin hệ thống
- Sau đó attacker gửi Tree Connect Request với path là \\10.0.0.133\ADMIN$ → attacker đã xác thực với user có quyền Admin
  - Biện pháp loại bỏ lây lan PsExec qua user thường
    - Cấu hình fireware chặn cổng 445 (SMB) kết nối ngang hàng (chỉ cho máy chuyên dụng được kết nối tới workstation)
    - Local Administrator Password Solution → xáo trộn password admin local để bẻ gãy tấn công Pass-The-Hash
      - Các máy join domain có pass khác nhau và tự động thay đổi sau 1 khoảng thời gian
- Gửi Create Request File với tên file bỏ trống để kiểm tra user có quyền với thư mục gốc (C:/Windows) không



- Sau khi xác nhận có quyền, attacker yêu cầu truy cập file PSEXESVC.exe. Server phản hồi file chưa tồn tại và tạo file



- PSEXESVC.exe là file thực thi dịch vụ PsExec cung cấp khả năng truy cập và thực thi từ xa

5. We need to know how the attacker installed the service on the compromised machine to understand the attacker's lateral movement tactics. This can help identify other affected systems. Which network share was used by PsExec to install the service on the target machine?

- Yêu cầu: tìm cách mà dịch vụ của attacker được cài trên máy nạn nhân → lateral movement tactic
- As: ADMIN$
- Như đã phân tích ở câu trước, attacker đã dùng thư mục chia sẻ Admin để cài đặt PsExec

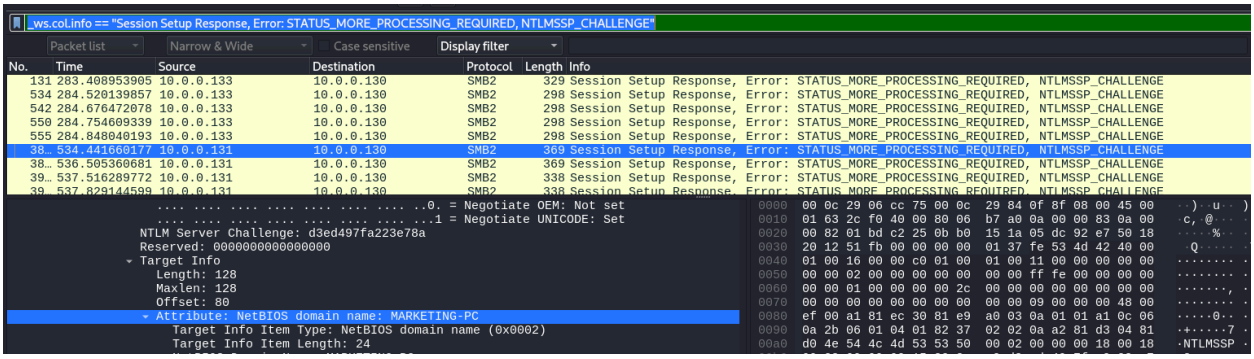
6. We must identify the network share used to communicate between the two machines. Which network share did PsExec use for communication?

- Yêu cầu: thư mục chia sẻ mà PsExec dùng để liên lạc giữa 2 máy
- As: IPC$
- IPC: Inter-Process Communication → cho phép các tiến trình trao đổi dữ liệu

    - Công ảo để chương trình máy này kết nối dịch vụ máy kia (chạy lệnh từ xa, xác thực tạo phiên làm việc)
- Như đã phân tích: Đầu tiên attacker gửi Tree Connect Request tới \\10.0.0.133\IPC$, attacker xem được
    - Lấy thông tin full user và group qua \pipe\samr
    - List thư mục chia sẻ công khai qua \pipe\srvsvc
    - Một số thông tin hệ thống

7. Now that we have a clearer picture of the attacker's activities on the compromised machine, it's important to identify any further lateral movement. What is the hostname of the second machine the attacker targeted to pivot within our network?

- Yêu cầu: tìm machine thứ 2 mà máy attacker nhắm mục tiêu
- As: MARKETING-PC
- Dùng bộ lọc _ws.col.info == "Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE" để kiểm tra attacker có dùng biện pháp tương tự để xác thực bằng machine khác không
- Lọc ra được machine với hostname MARKETING-PC là máy thứ 2 mà attacker gửi xác thực tới



- Sau khi kiểm tra phát hiện attacker cũng push file độc hại lên máy này

←	38…	536.508858165	10.0.0.131	10.0.0.130	SMB2	474 Ioctl Response FSCTL_QUERY_NETWORK_INTERFACE_INFO
	38…	536.509453380	10.0.0.130	10.0.0.131	SMB2	234 Create Request File:
	38…	536.509655739	10.0.0.131	10.0.0.130	SMB2	298 Create Response File:
	38…	536.510013078	10.0.0.130	10.0.0.131	SMB2	146 Close Request File:
	38…	536.510181193	10.0.0.131	10.0.0.130	SMB2	182 Close Response
	38…	536.510589012	10.0.0.130	10.0.0.131	SMB2	382 Create Request File: PSEXESVC.exe
	38…	536.511108734	10.0.0.131	10.0.0.130	SMB2	410 Create Response File: PSEXESVC.exe
	38…	536.511701966	10.0.0.130	10.0.0.131	TCP	1514 49703 → 445 [ACK] Seq=1828 Ack=2189 Win=261888 Len=146

- Sau khi cài thành công công cụ, PsExec sẽ tạo các Named Pipes để 2 máy trao đổi lệnh từ xa
  - Thường là `\PSEXESVC` (hoặc `\pipe\psexecsvc` tùy phiên bản)
  - Có thể coi là IOC nhưng nếu attacker dùng mã nguồn mở thì có thể sửa

3. Mitre ATTCK

1. Execution

- T1569.002: **System Services: Service Execution**
  - PsExec đăng ký một dịch vụ để chạy file thực thi của nó

2. Defense Evasion

- T1078.002: **Valid Accounts: Domain Accounts**
  - Lấy được Domain Acc và truy cập vào thư mục chia sẻ của máy khác
- T1550.002: **Use Alternate Authentication Material: Pass the Hash**
  - Xác thực kết nối SMB bằng mã hash

3. Discovery

- T1135: **Network Share Discovery**
  - Thu thập thông tin từ thư mục chia sẻ của để làm tiền đề cho Lateral Movement

4. Lateral Movement

- T1021.002: **Remote Services: SMB/Windows Admin Shares**
  - Sử dụng acc hợp lệ để kết nối và tương tác với thư mục chia sẻ qua giao thức SMB